CO2 – ASSIGNMENT 2

EVALUATION AND ENGINEERING OF FOOTPRINTING, \nRECONNAISSANCE AND SOCIAL-ENGINEERING-AWARENESS WORKFLOWS

Academic Details	Information
Course Code	ITA1439
Course Name	Ethical Hacking
Course Outcome	CO2 – Footprinting and social-engineering techniques
Assignment Type	Individual
Student Name	T. Siva
Register Number	192425313
Slot	A
Submission Date	3-11-2026

Academic Year 2026–2027

DECLARATION

I hereby declare that this assignment report titled "Evaluation and Engineering of Footprinting, Reconnaissance and Social-Engineering-Awareness Workflows in an Authorized Assessment" has been prepared for the course ITA1439 – Ethical Hacking. The work is presented for academic purposes and follows the authorized-scope requirements stated in the assignment brief.

I understand that reconnaissance activities must be conducted only on systems, domains and datasets for which explicit permission has been granted. No real individual is targeted, and no unauthorized attack or social-engineering attempt is performed.

Student Signature: T. Siva

Date: 3-11-2026

ABSTRACT

Footprinting and reconnaissance provide an organized view of an organization's publicly observable digital presence. However, information collected from WHOIS/RDAP, DNS, search engines, archived pages and public business sources can be incomplete, stale, duplicated or outside the authorized scope. This report designs and

evaluates seven connected workflows for an authorized assessment. It combines multi-source footprinting, DNS record analysis, competitiveintelligence awareness, data validation, hierarchical traversal and constrained approach comparison. The final integrated review diagnoses a workflow limitation, proposes a redesigned validation sequence and evaluates the change using measurable criteria.

The report uses reserved example domains, fictional organizations and illustrative lab observations to demonstrate the method safely. These sample values are not represented as live measurements against a real organization. Actual command outputs and timestamps should be inserted after execution in a lab environment owned by the student or explicitly authorized by the institution.

KEYWORDS

Footprinting, reconnaissance, WHOIS, RDAP, DNS, dig, nslookup, competitive intelligence, socialengineering awareness, data validation, scope control, authorized assessment.

TABLE OF CONTENTS

1. 1. Introduction and assessment approach
2. 2. Q1 – Footprinting strategy design and evaluation
3. 3. Q2 – Reliable DNS footprinting workflow
4. 4. Q3 – Competitive-intelligence awareness utility
5. 5. Q4 – Reconnaissance data-validation mechanism
6. 6. Q5 – Hierarchical organization footprinting
7. 7. Q6 – Footprinting approaches under constraints
8. 8. Q7 – Integrated review: diagnose, redesign and defend
9. 9. Overall findings and conclusion
10. 10. References
11. Appendix A – Command reference
12. Appendix B – Evidence collection templates

1. INTRODUCTION AND ASSESSMENT APPROACH

1.1 Introduction

Footprinting is the systematic collection of information about a target organization before a security assessment. It helps an assessment team understand the external attack surface, identify exposed services and recognize information that may increase operational or human risk. A sound footprinting process does not assume that one source is complete. WHOIS/RDAP may show registration information, DNS may reveal host and mail infrastructure, search engines may index documents, and archived pages may preserve older content.

1.2 Problem statement

A reconnaissance workflow can produce a misleading picture when it trusts one source, ignores freshness, fails to separate authorized and unauthorized assets, or collects the same information repeatedly. The engineering problem is to maximize useful and reliable coverage while minimizing unnecessary queries, false conclusions and scope violations.

1.3 Objectives

- Design a repeatable multi-source footprinting strategy and classify passive and active techniques.
- Retrieve and interpret A, MX, NS and TXT records, with zone-transfer checks only when authorized.
- Convert public business information into a human-risk awareness assessment without targeting real people.
- Validate collected items for scope, freshness, duplication and source reliability.
- Represent an organization as a hierarchy and traverse it with explicit boundary conditions.
- Compare passive and active approaches under increasing scope and resource constraints.
- Diagnose one workflow limitation, redesign it and defend the result with measurable evidence.

1.4 Scope, ethics and authorization

All examples in this report are designed for a controlled lab. The reserved domains example.com, example.net and example.org are used for documentation examples; fictional names ending in .test are used as conceptual lab labels. Before any real execution, the assessor must obtain written authorization, define exact domains and IP ranges, identify permitted query types, specify a time window and record exclusions. A zone-transfer attempt must never be directed at a third-party name server without explicit permission.

1.5 Common assessment lifecycle

Figure 1. Multi-source footprinting strategy



The lifecycle begins with scope confirmation and ends with a defensible risk assessment. Every collected item is linked to its source, collection time, scope decision and confidence rating.

1.6 Evidence and measurement conventions

Evidence field	Purpose	Example format
Evidence ID	**Unique traceability identifier**	**DNS-001**
Target / asset	**Authorized asset label**	**lab.example.test**
Source	**Tool, operator or public source**	**dig / WHOIS / search operator**
Observation time	**Freshness and repeatability**	**2026-11-03 10:00 IST**
Observed value	**Raw result or concise extract**	**A record: 192.0.2.10**
Scope status	**In-scope / out-of-scope / uncertain**	**In-scope**
Confidence	**High / medium / low**	**High – corroborated**
Disposition	**Pass / re-query / reject**	**Pass**

Documentation convention: IP addresses from TEST-NET ranges (192.0.2.0/24, 198.51.100.0/24 and 203.0.113.0/24) are illustrative documentation addresses. All numerical observations in the worked examples are synthetic unless a student replaces them with genuine authorized lab evidence.

2. Q1 – EVALUATE AND ENGINEER A FOOTPRINTING STRATEGY (8 MARKS)

2.1 Problem interpretation

The task requires a combined strategy using WHOIS, DNS, search-engine operators and archived pages. The strategy must distinguish passive from active methods, organize results by source, handle four contrasting target

profiles, compare predictions with observations, judge reliability and adapt to a larger scope of fifty subdomains and several third-party services.

2.2 Proposed strategy

Figure 1. Multi-source footprinting strategy



Technique	Type	Information sought	Limitations / safeguards
WHOIS / RDAP lookup	**Passive**	**Registrar, registration dates, name servers, status**	**Privacy redaction and registrar data may limit visibility.**
Search-engine operators	**Passive**	**Indexed pages, documents, exposed technical references**	**Index may be stale; do not assume a result is current.**
Archived pages	**Passive**	**Historical page content and retired paths**	**Historical content may no longer be accessible or valid.**
DNS queries (A, MX, NS, TXT)	**Active query / low-impact**	**Address, mail, authoritative DNS and policy records**	**Query only authorized names; resolver cache affects results.**
Authorized service verification	**Active**	**Confirm a known service or endpoint**	**Only within written scope and approved rate limits.**

2.3 Scope definition and target profiles

Four fictional target profiles are used to test the strategy. These are designed cases, not claims about real organizations.

Target case	Expected profile	Prediction before collection	Illustrative observation
T1 – Protected	**Minimal public metadata; controlled DNS**	**Few indexed technical details; consistent records**	**WHOIS privacy enabled; A/MX/NS/TXT coherent; no sensitive public document**
			located.
T2 – Information-leaking	**Many indexed documents and legacy references**	**Documents may reveal technology names and old contact routes**	**Public reports and archived pages reveal old platform names; current status requires confirmation.**
T3 – DNS-misconfigured	**Inconsistent or stale DNS configuration**	**Unexpected records, stale hosts or excessive TXT content**	**One stale host record and inconsistent TTL values appear in the synthetic test set.**
T4 – Minimal footprint	**Little indexed content and few public references**	**Few sources return useful items**	**Search and archive queries return little; low visibility is not proof of no exposure.**

2.4 Collection procedure

13. Freeze the engagement scope: exact parent domain, permitted subdomains, excluded third parties, time window and approved tools.
14. Create an evidence register before collecting data; assign an ID to each query and each returned item.
15. Perform passive collection first: registration data, indexed pages, public reports and archived snapshots.
16. Query authorized DNS records and capture the resolver, timestamp, TTL and complete output.
17. Normalize hostnames and compare evidence across sources; mark contradictions rather than silently choosing one.
18. Validate scope, freshness and reliability before using an item in risk analysis.
19. Prepare a prediction-versus-observation table and document uncertainty and collection limitations.

2.5 Safe command examples

```
# Passive registration lookup (use only an authorized domain) whois
example.com

# DNS record queries for a domain included in the engagement scope dig
example.com A dig example.com MX dig example.com NS dig example.com
TXT

# Alternative resolver query; record which resolver was used
nslookup -type=A example.com nslookup -type=MX example.com

# Search-engine operator examples (manual browser use)
site:example.com filetype:pdf site:example.com intitle:annual
report site:example.com "security policy"
```

These commands demonstrate syntax only. Replace example.com with a domain explicitly listed in the signed scope. Search operators should be used to locate public material, not to access restricted resources.

2.6 Source reliability and contradiction handling

Source	Reliability considerations	Contradiction example	Resolution
WHOIS / RDAP	Registration data may be privacy-protected or delayed.	WHOIS name server differs from current DNS delegation.	Record both; query authoritative delegation and note observation time.
DNS	Resolver cache, splithorizon DNS and TTL can change answers.	Two resolvers return different A records.	Repeat using documented resolvers and classify viewpoint difference.
Search index	Indexing delay and snippets may preserve old content.	Search result shows an old subdomain.	Open the public page if available and confirm current DNS separately.
Archive	Historical snapshot is not a current asset inventory.	Archived page links to retired service.	Label historical; do not add to current attack surface without validation.

2.7 Changed condition: scale to 50 subdomains and third parties

At larger scale, the original manual workflow becomes difficult to repeat and audit. The strategy should be modified into a controlled pipeline with an approved asset inventory, a queue, rate limits, deduplication, source provenance and exception handling. Third-party services must be explicitly listed or separately authorized; discovering a vendor hostname does not automatically grant permission to test it.

- Use an allowlist generated from the signed scope; reject any hostname not matching an approved rule.
- Batch passive queries and DNS lookups with conservative rate limits and retry limits.
- Normalize case, trailing dots and internationalized hostnames before deduplication.
- Store raw output separately from parsed fields so results can be reproduced.
- Use a status queue: pending, collected, validated, re-query required, rejected and reviewed.
- Report coverage as validated in-scope assets divided by total approved assets, not simply the number of queries.

2.8 Q1 evaluation

Evaluation criterion	Small engagement	50-subdomain engagement	Engineering decision
Coverage	**Manual checklist is practical.**	**Manual tracking risks omissions.**	**Use an inventory-driven queue at scale.**
Reliability	**Cross-check key findings manually.**	**Automated normalization and review are needed.**	**Keep human review for contradictions.**
Scope compliance	**Single allowlist is manageable.**	**Third-party boundaries become complex.**	**Fail closed when scope is uncertain.**
Efficiency	**A small number of queries**	**Batching and deduplication**	**Optimize only after scope**
	is acceptable.	**reduce repeated work.**	**controls are enforced.**

Q1 conclusion: A multi-source strategy gives better coverage than a single-source approach, but only when each item retains provenance, freshness and scope status. For fifty subdomains, an allowlist-driven and auditable workflow is preferable to ad-hoc collection.

3. Q2 – BUILD A RELIABLE DNS FOOTPRINTING WORKFLOW (7 MARKS)

3.1 DNS assessment objective

The objective is to retrieve A, MX, NS and TXT records, interpret delegation and caching, and evaluate zone-transfer exposure only on a server explicitly authorized for the test. DNS data must be interpreted as a time- and resolver-dependent view, not as a permanent truth.

Figure 2. DNS footprinting workflow



3.2 Record types and security relevance

Record	Purpose		Potential assessment value	Caution
A	Maps a hostname to an IPv4 address.		Identifies published host destinations.	Address may be a CDN, proxy or shared host.
MX	Lists mail exchangers and preference.		Shows mail routing providers.	Third-party mail provider is not automatically in scope.
NS	Identifies authoritative name servers.		Shows DNS delegation and provider relationships.	Parent and child delegations may differ.
TXT	Publishes text data such as SPF or verification strings.		Can reveal mail policy and service integrations.	Avoid exposing or reproducing secrets; treat unexpected tokens carefully.
AXFR	DNS zone transfer mechanism.		A permitted test can determine whether a zone is transferable.	Attempt only against an explicitly authorized lab/target server.

3.3 DNS workflow and command sequence

```
# Query records for an authorized test domain dig
lab.example.test A dig lab.example.test MX dig
lab.example.test NS dig lab.example.test TXT

# Query a chosen resolver to document the viewpoint dig
@192.0.2.53 lab.example.test A
```

```
# nslookup equivalents nslookup -
type=A lab.example.test nslookup -
type=MX lab.example.test nslookup -
type=NS lab.example.test nslookup -
type=TXT lab.example.test

# Zone transfer: only when written authorization explicitly permits it #
Replace AUTHORIZED_NS with the approved lab name server. dig
@AUTHORIZED_NS lab.example.test AXFR
```

The AXFR command is included as a controlled-lab example. Do not run it against public or thirdparty infrastructure unless the engagement authorization explicitly names the server and test.

3.4 Six contrasting DNS test cases

Case	Configuration	Predicted result	Illustrative observation	Assessment
D1	Correctly secured DNS	A/MX/NS/TXT returned; AXFR refused	Expected records returned; transfer refused	Good baseline; no transfer exposure observed.
D2	AXFR permitted in isolated lab	Zone records may be returned	Synthetic lab returned 12 zone entries	High information exposure; restrict transfers.
D3	Stale record	Old address remains visible	Old TEST-NET address returned with long TTL	Re-query and compare authoritative data.
D4	Split-horizon DNS	Internal and external answers differ	External resolver returned public address only	Viewpoint must be documented.
D5	Third-party delegation	NS points to provider	Provider NS records returned	Record relationship; do not test provider without scope.

D6	**TXT policy variation**	**TXT may contain SPF or verification values**	**Multiple TXT strings returned**	**Interpret policy; redact sensitive tokens if any.**

3.5 Prediction-versus-observation analysis

For each case, the prediction is written before executing the query. The observation column above is an illustrative lab outcome used to demonstrate analysis. During actual lab work, replace it with the complete raw output, resolver, date/time and TTL.

Observation item	Expected interpretation	Possible source of error	Required follow-up
Different A records across resolvers	**Possible cache, splithorizon or load balancing**	**Resolver cache or geographic routing**	**Repeat queries; record resolver and TTL.**
No MX record	**Domain may not receive mail directly**	**Mail service may be configured elsewhere**	**Check approved documentation; do not infer absence of email.**
Many TXT records	**Multiple verification or**	**Stale service-verification**	**Identify purpose and**
	policy entries	**records**	**current relevance.**
AXFR refused	**Transfer not available to tested client**	**ACL or TSIG controls may be present**	**Record refusal; do not label the entire DNS service secure.**
AXFR succeeds in lab	**Zone content is exposed to the authorized tester**	**Lab configuration intentionally permits transfer**	**Restrict transfer to approved secondary servers; consider TSIG.**

3.6 Split-horizon, delegation and caching

- Split-horizon DNS provides different answers to different network locations or resolver views. An external tester may see only public records.
- Delegation transfers authority for a child zone to another name server. The parent zone may show only the delegated NS set.
- Caching allows resolvers to reuse previous answers until TTL expiry. Two resolvers can temporarily return different data.
- Negative caching can also affect the visibility of recently created records.
- The report should capture resolver identity, query time, TTL, response code and whether the answer is authoritative.

3.7 Countermeasure and redesign

A zone transfer should be permitted only to approved secondary name servers. Access-control lists should restrict AXFR by source address, and TSIG should authenticate transfer requests where supported. Monitoring should alert on unexpected transfer attempts. The redesigned test verifies that an unauthorized lab client is refused while the approved secondary remains able to synchronize.

Control	Implementation intent	Validation evidence
Transfer ACL	**Allow only approved secondary server addresses.**	**Unauthorized lab client receives refusal.**
TSIG	**Authenticate zone-transfer peers using shared keys.**	**Transfer succeeds only with valid authentication.**
Least privilege	**Expose only necessary DNS data publicly.**	**Review public records against approved design.**
Monitoring	**Log transfer requests and unusual query patterns.**	**A test event appears in DNS audit logs.**

Q2 conclusion: Reliable DNS footprinting requires record-by-record interpretation and explicit documentation of resolver viewpoint. A successful zone transfer is a configuration risk in the authorized lab, while refusal alone is not proof that every DNS control is correct.

4. Q3 – CREATE A COMPETITIVE-INTELLIGENCE AWARENESS UTILITY (7 MARKS)

4.1 Purpose and ethical boundary

The utility collects public business information to understand how it could be misused in socialengineering scenarios. It is an awareness and defensive-planning exercise only. No phishing, vishing, pretexting or tailgating attempt is performed against a real person.

Figure 3. Competitive-intelligence awareness pipeline



4.2 Public sources and search operators

Public source	Example search operator	Potential information	Defensive use
Job advertisements	site:example.com/jobs	Roles, tools, departments, hiring processes	Teach staff to verify recruitment-related requests.
Annual reports	site:example.com filetype:pdf	Organization structure, locations, business priorities	Identify details that should not be used as authentication factors.
Press releases	site:example.com intitle:news	Projects, vendors, events, leadership announcements	Build verification guidance for urgent project-related requests.
Public professional profiles	site:example.com "team"	Public role descriptions and reporting relationships	Promote safe handling of role-based impersonation.
Public policy pages	site:example.com "visitor policy"	Visitor procedures and publicly disclosed processes	Review whether physicalaccess instructions reveal too much.

4.3 Item-to-technique and indicator mapping

Public item	Could enable	Warning indicator	Recommended countermeasure
Published job role and technology stack	Phishing / pretexting	Message refers to a specific tool or project and requests credentials.	Verify through known internal channels; never share passwords or OTPs.
Public office phone number	Vishing	Caller pressures staff to disclose account or employee details.	Call back using an independently verified directory number.
Public project	Pretexting	Unexpected request claims	Validate sender and
announcement		to be from a project partner.	request through an approved ticket or manager.
Visitor or event information	Tailgating	Unknown person asks to enter by following an employee.	Challenge politely and follow visitor registration procedures.
Annual report with leadership roles	Impersonation / phishing	Urgent payment or data request appears to come from an executive.	Use dual approval and outof-band confirmation.

4.4 Test organization profiles

Test organization	Public information profile	Predicted human-risk level	Illustrative finding
ORG-A – Rich	**Many reports, job posts, press releases and public profiles**	**Medium to high exposure**	**More context exists for tailored impersonation; controls determine actual risk.**
ORG-B – Sparse	**Few pages and limited public details**	**Low to medium exposure**	**Less contextual detail; basic phone and email impersonation remain possible.**
ORG-C – Misleading	**Old announcements and inconsistent public pages**	**Medium exposure with high uncertainty**	**Outdated details may support plausible but inaccurate pretexts.**

4.5 Risk scoring model

A simple awareness score can prioritize review without claiming to predict whether a person will be deceived. Rate each public item on a 1–5 scale for specificity, ease of misuse and potential impact. The score is the product of the three values (range 1–125). A high score indicates that the item deserves stronger defensive treatment, not that an attack will succeed.

Factor	1 – Low	3 – Moderate	5 – High
Specificity	**Generic public fact**	**Identifies a team or process**	**Reveals detailed operational context**
Ease of misuse	**Difficult to turn into a credible request**	**Could support a tailored message**	**Directly supports a convincing impersonation pretext**
Potential impact	**Minor inconvenience**	**Limited data or workflow disruption**	**Could affect credentials, money or physical access**

4.6 Adding two sources / two countermeasures

Two additional defensive sources are (1) public procurement notices and (2) public event or conference schedules. They can reveal vendor relationships and time-bound organizational activity. Their inclusion should be governed by the same source-provenance and minimization rules.

- Countermeasure 1 – Out-of-band verification: sensitive requests are confirmed using a previously known phone number or internal channel, not the contact details supplied in the suspicious message.

- Countermeasure 2 – Physical visitor control: visitors are registered, issued visible identification and escorted where required; employees are trained not to permit unauthorized piggybacking.

4.7 Utility workflow and output schema

For each public item:
1. **Confirm that the source is public and within the assessment scope.**
2. **Record URL, title, source type, access date and short factual summary.**
3. **Remove unnecessary personal information from the working dataset.**
4. **Map the item to a possible social-engineering technique.**
5. **Identify the warning indicator a staff member should notice.**
6. **Assign an awareness priority and recommend a control.**
7. **Have a reviewer verify the interpretation before reporting.**

Field	Example value
Item ID	**CI-004**
Source category	**Public press release**
Factual summary	**A new customer-support platform was announced.**
Potential misuse category	**Pretexting**
Human indicator	**Unexpected request to log in through a supplied link.**
Awareness priority	**Medium**
Countermeasure	**Navigate to the known portal independently.**
Personal data handling	**No individual-level personal data retained.**

Q3 conclusion: Public information can increase the plausibility of impersonation attempts, but the assignment is completed through mapping, risk assessment and awareness controls—not through contacting or deceiving real people.

5. Q4 – DESIGN A RECONNAISSANCE DATA-VALIDATION MECHANISM (6 MARKS)

5.1 Validation problem

Reconnaissance data may be incomplete, stale, duplicated, unverifiable or out of scope. Using such data can waste effort and may violate the engagement boundary. Each item therefore requires a deterministic disposition: pass, re-query or reject.

Figure 4. Reconnaissance data-validation gate



5.2 Validation rules

Check	Pass condition	Recoverable condition	Reject condition
Scope	Asset exactly matches approved scope or rule.	Scope entry is ambiguous and can be confirmed by owner.	Asset is explicitly excluded or unrelated.
Freshness	Within the agreed freshness window.	Old result can be refreshed safely.	Historical-only item is incorrectly presented as current.
Duplication	Unique normalized item or meaningful new observation.	Possible duplicate needs comparison.	Exact duplicate adds no new evidence.
Source reliability	Traceable source with sufficient confidence.	Source can be corroborated.	Unverifiable source or fabricated result.

5.3 Disposition logic

```
function validate(item, scope, now):     if not
matches_scope(item.asset, scope):        return REJECT     if
item.source is missing or item.value is unverifiable:
return REJECT     if is_duplicate(normalize(item),
accepted_items):
       return REJECT     if is_stale(item.timestamp,
freshness_window):        return REQUERY     if
item.confidence < minimum_confidence:        return
REQUERY     return PASS
```

The order is deliberately fail-closed: scope is checked first so out-of-scope material is rejected before additional processing. Source traceability is checked before spending effort on refresh or correlation.

5.4 Five adversarial test sequences

Sequence	Input set	Predicted disposition	Reason
V1 – All valid	**Four in-scope, current, unique, traceable items**	**4 pass; 0 re-query; 0 reject**	**All checks satisfied.**
V2 – Out of scope	**Three valid items plus one excluded hostname**	**3 pass; 0 re-query; 1 reject**	**Boundary violation is rejected first.**
V3 – Stale	**Three current items plus one old DNS observation**	**3 pass; 1 re-query; 0 reject**	**Old item may be refreshed.**
V4 – Duplicate	**Three unique items plus one repeated record**	**3 pass; 0 re-query; 1 reject**	**Duplicate contributes no additional evidence.**
V5 – Mixed quality	**Two valid, one stale, one out-of-scope, one unverifiable**	**2 pass; 1 re-query; 2 reject**	**Each item receives the first decisive disposition.**

5.5 Validation-order evaluation

A validation sequence should reject clear scope violations early. Checking expensive freshness or corroboration before scope can waste time on items that must never be used. Duplicate detection is also useful before expensive enrichment, but the normalized key must preserve meaningful differences such as record type, resolver and observation time.

Order	Sequence	Expected effort	Risk
Original illustrative order	**Freshness → source reliability → duplicate → scope**	**Higher effort on invalid items**	**Scope violation may be processed too far before rejection.**
Redesigned order	**Scope → traceability → normalize/deduplicate → freshness → confidence**	**Lower avoidable effort**	**Requires a correct and maintained scope allowlist.**

5.6 Scale from one to fifty targets

For one target, manual review is practical. At fifty targets, the same checks should be implemented as a repeatable pipeline with a versioned allowlist, normalized keys, freshness windows and an exception queue. The system should report the number of items in each disposition category and retain the reason for each decision.

Scale	Illustrative items	Expected control	Operational note
1 target	20 evidence items	Manual review checklist	Suitable for a small teaching exercise.
10 targets	200 evidence items	Structured spreadsheet or script	Use consistent identifiers and normalized fields.
50 targets	1,000 evidence items	Automated validation plus human exception review	Monitor scope changes and false duplicate matches.

Q4 conclusion: Scope-first validation is the safest and most efficient order when the allowlist is authoritative. Stale but in-scope items should normally be re-queried; out-of-scope or unverifiable items should be rejected

6. Q5 – EVALUATE FOOTPRINTING OF A HIERARCHICAL ORGANIZATION (7 MARKS)

6.1 Hierarchical representation

An organization's public footprint can be represented as a tree or directed hierarchy. The parent domain is the root; subdomains and departmental services are child nodes; approved third-party services may appear as linked leaves. A discovered third-party node is recorded as a relationship but is not traversed or tested unless it is explicitly in scope.

Figure 5. Hierarchical footprint traversal



6.2 Example hierarchy

```
corp.example.test                    [ROOT]
|
+-- www.corp.example.test            [PUBLIC WEB]
|   +-- careers.corp.example.test    [CAREERS]
|   +-- support.corp.example.test    [SUPPORT]
|
+-- mail.corp.example.test           [MAIL]
|
+-- research.corp.example.test       [DEPARTMENT]
|   +-- portal.research.corp.example.test [PORTAL]
|   +-- archive.research.corp.example.test[EMPTY / NO PUBLIC DATA] |
+-- vendor-service.example.net       [THIRD PARTY - OUT OF SCOPE]
```

The hierarchy is illustrative. The vendor node is shown to demonstrate a boundary and must not be queried further unless separate authorization is recorded.

6.3 Traversal algorithm

```
procedure traverse(root, approved_scope):
create queue and add root     visited = empty
set

   while queue is not empty:
node = remove_front(queue)

      if node in visited:
continue
      add node to visited

      if node not in approved_scope:
record(node, "OUT OF SCOPE - STOP")
continue

      record(node, "IN SCOPE")
      children = discover_documented_children(node)

      if children is empty:
         record(node, "TERMINAL / NO PUBLIC DATA")
         continue

      for child in children:           if
child in approved_scope:
add child to queue           else:
            record(child, "BOUNDARY - NOT TRAVERSED")
```

6.4 Test structures and predictions

Structure	Shape	Predicted nodes	Boundary / terminal condition
H1 – Shallow	Root with 3 direct children	4 nodes	All child nodes terminal.
H2 – Deep	Root → department → portal → archive	4 nodes	Archive is terminal; depth is 4.
H3 – Irregular	Root with branches of different sizes and one empty branch	8 in-scope nodes plus 1 excluded reference	Empty branch terminates; excluded vendor is not traversed.

6.5 Illustrative traversal results

Test	Predicted coverage	Illustrative visited count	Result
H1	**4 of 4**	**4**	**Complete within scope.**
H2	**4 of 4**	**4**	**Deep path completed; terminal archive recorded.**
H3	**8 of 8 in-scope**	**8 in-scope; 1 excluded node recorded as boundary**	**No out-of-scope traversal.**

6.6 Depth, branching and complexity

For a hierarchy with V approved nodes and E discovered relationships, a breadth-first or depthfirst traversal visits each node at most once when a visited set is maintained. The graph-processing cost is O(V + E), excluding the time required for external queries. Greater depth increases the number of sequential discovery stages; greater branching increases the number of nodes that may need processing. Rate limits and authorization checks remain necessary regardless of algorithmic complexity.

6.7 Systematic versus ad-hoc traversal

Dimension	Systematic traversal	Ad-hoc approach
Coverage	**Tracks visited nodes and known branches.**	**May overlook branches or repeat checks.**
Boundary handling	**Explicit allowlist and stop condition.**	**Scope decisions may be inconsistent.**
Reproducibility	**Same traversal rules can be rerun.**	**Depends heavily on operator memory.**
Auditability	**Node status and evidence ID recorded.**	**Often lacks a complete traversal log.**
Flexibility	**Requires maintaining the hierarchy and scope rules.**	**Can adapt quickly but is less predictable.**

Q5 conclusion: A systematic traversal with a visited set, explicit scope allowlist and terminal-node rule provides predictable coverage. Empty branches must be recorded as terminal rather than treated as traversal failures.

7. Q6 – EVALUATE FOOTPRINTING APPROACHES UNDER CONSTRAINTS (7 MARKS)

7.1 Approaches selected

Two approaches are compared on the same authorized lab inventory: (A) passive open-source collection, which reviews publicly indexed information without directly querying target services; and (B) active DNS footprinting, which sends DNS queries to obtain current record responses. Active DNS querying is limited to the approved domain list and conservative query rates.

Approach	Typical output	Strength	Limitation
A – Passive OSINT	**Indexed pages, public documents, registration details, archived content**	**Low direct interaction with target infrastructure**	**Index freshness and completeness are uncertain.**
B – Active DNS	**A, MX, NS and TXT observations with resolver and TTL**	**Structured, current DNS view from the chosen resolver**	**Results depend on resolver view; creates direct query traffic.**

7.2 Comparative workflow

20. Use the same approved target inventory for both approaches.
21. For passive collection, define a fixed set of search operators and public sources.
22. For active DNS collection, query the same record types for each approved hostname.
23. Record query count, unique validated findings, duplicate count, elapsed time and scope exceptions.
24. Repeat the test under increasing scope sizes using the same rules and rate limits.
25. Compare usefulness and coverage rather than declaring one approach universally superior.

7.3 Increasing scope sizes

The following values are a worked synthetic example to show how measurements should be reported. They are not captured measurements from a live engagement. Replace them with your actual lab timings and counts.

Scope size	Passive queries / steps	Active DNS queries	Passive unique findings	Active unique findings
1 domain	**8**	**4**	**5**	**4**
5 domains	**40**	**20**	**19**	**17**
20 domains	**160**	**80**	**54**	**68**
50 domains	**400**	**200**	**91**	**164**

7.4 Illustrative efficiency and redundancy analysis

Approach	Repeated / redundant work	Where effort is wasted	Improvement
Passive OSINT	**Same search result appears for multiple operators;**	**Reviewing duplicates and outdated snippets.**	**Normalize URLs, hash document content and label**
	archived pages repeat content.		**historical data.**
Active DNS	**Same hostname queried repeatedly; aliases resolve to common destinations.**	**Re-querying unchanged records before TTL expiry.**	**Cache by hostname, type, resolver and timestamp; refresh when justified.**

7.5 Is faster or quieter always better?

No. A quieter approach may miss current DNS information, while a faster active query set may provide incomplete context about business processes and historical exposure. The engineering choice depends on the assessment objective, authorization, scope size, time budget, required evidence and risk of operational impact.

Engagement context	Recommended approach	Reason
Small-scope teaching exercise	**Start with passive OSINT, then perform limited active DNS queries.**	**Students can compare source types and validate a small number of findings.**
Large-scope authorized assessment	**Use a hybrid pipeline: passive discovery plus allowlist-driven active DNS verification.**	**Passive sources broaden context; DNS checks validate current records at scale.**
Strictly low-interaction engagement	**Prioritize passive collection and use active queries only when explicitly approved.**	**Minimizes direct interaction while clearly documenting coverage limitations.**

Q6 conclusion: Neither speed nor stealth is a sufficient decision criterion by itself. A hybrid, scopecontrolled method provides a stronger balance of context, current technical evidence and auditability.

8. Q7 – INTEGRATED REVIEW: DIAGNOSE, REDESIGN AND DEFEND (8 MARKS)

8.1 Selected workflow and limitation

The selected workflow is Q4, the reconnaissance data-validation mechanism. Its original illustrative order checks freshness and source reliability before checking scope. This can waste time processing items that should be rejected immediately because they are outside the approved boundary.

A. Diagnose the limitation (2 marks)

The bottleneck is inefficient validation ordering. An out-of-scope item may be refreshed, enriched or corroborated before the scope check rejects it. This creates unnecessary work and increases the chance that unauthorized data is retained or used.

Observed design weakness	Evidence used for diagnosis	Impact
Scope check occurs late.	Original sequence: freshness → reliability → duplicate → scope.	Invalid items consume processing effort before rejection.
No explicit reason code.	A simple pass/fail result does not explain the decision.	Reviewers cannot easily audit or recover uncertain records.
Duplicate check lacks normalization.	Different capitalization or trailing dots may evade exact matching.	Repeated evidence may inflate coverage.

B. Establish evaluation criteria (1 mark)

Metric	Definition	Desired direction
Validated coverage	Unique in-scope items passed / total expected in-scope items × 100	Higher
Unnecessary checks	Checks performed on items already known to be out of scope	Lower
Scope compliance	Out-of-scope items accepted into validated output	Zero accepted
Disposition accuracy	Correct pass / re-query / reject classification against test labels	Higher
Traceability	Items with source, timestamp, scope decision and reason code	100%

C. Propose and implement a redesign (2 marks)

Figure 6. Evidence-led redesign cycle



The redesigned sequence checks scope first, followed by source traceability, normalization and duplicate detection, freshness, and confidence. This ordering removes clearly out-of-scope items before additional processing. The trade-off is that the allowlist must be accurate and maintained whenever the engagement scope changes.

REDESIGNED VALIDATION

Input: evidence item, approved scope, accepted-item index

1. **Normalize asset name and evidence key.**
2. **If asset is not in approved scope:**
   mark REJECT_SCOPE; stop.
3. **If source or collection timestamp is missing:**
   mark REJECT_UNVERIFIABLE; stop.
4. **If normalized evidence is already accepted:**
   mark REJECT_DUPLICATE; stop.
5. **If evidence is outside freshness window:**
   mark REQUERY_STALE; stop.
6. **If source confidence is below threshold: mark REQUERY_CONFIRMATION; stop.**
7. **Otherwise:**
   mark PASS and store provenance.

D. Validate and compare (2 marks)

Both workflows are evaluated against the same five synthetic test sequences from Q4. The numbers below are illustrative counts of checks, not measured execution-time claims. “Checks” count the validation stages reached across the evidence items.

Test sequence	Items	Original checks (illustrative)	Redesigned checks (illustrative)	Expected final disposition
V1 – All valid	4	16	16	4 pass
V2 – One out of scope	4	16	13	3 pass, 1 reject
V3 – One stale	4	16	16	3 pass, 1 re-query
V4 – One duplicate	4	16	13	3 pass, 1 reject
V5 – Mixed quality	5	20	14	2 pass, 1 re-query, 2 reject

Interpretation: The redesigned sequence reduces checks in cases where an early scope or duplicate decision is decisive. It does not reduce work for all-valid or stale-only cases because those items must proceed through the remaining validation stages. The design goal is not to minimize every check; it is to avoid unnecessary checks while preserving correct disposition.

E. Defend the final engineering judgment (1 mark)

The redesigned workflow is preferred for repeated assessments because it enforces the authorization boundary early, produces reason-coded decisions and reduces avoidable processing for out-of-scope and duplicate items. The original sequence may still be acceptable for a very small, pre-filtered dataset where scope is already guaranteed and the validation order has negligible overhead. The redesigned approach depends on a current allowlist; if that list is incomplete or outdated, legitimate assets could be incorrectly rejected. Therefore, scope changes must be versioncontrolled and reviewed by the engagement owner.

8.2 Final decision table

Decision question	Final judgment
Did the redesign meet its objective?	**Yes, for the tested synthetic cases: early rejection reduced unnecessary checks without changing expected dispositions.**
Was scope compliance preserved?	**Yes, out-of-scope items are rejected before enrichment or refresh.**
What is the main trade-off?	**The allowlist requires maintenance and may reject newly approved assets until updated.**
When is the original preferable?	**A tiny, already scope-filtered dataset with minimal duplication and no need for scalable audit controls.**
Recommended deployment	**Use the redesigned sequence with versioned scope, reason codes, evidence provenance and periodic review.**

Q7 conclusion: The redesign is supported by test-case reasoning and measurable processing-stage counts. For a real submission, execute both versions against the same local synthetic dataset, save the outputs and replace the illustrative counts with observed results.

9. OVERALL FINDINGS AND CONCLUSION

9.1 Consolidated findings

Question	Main engineering finding	Evidence artifact
Q1	**Multiple sources improve coverage; provenance and scope controls prevent misleading conclusions.**	**Strategy matrix, target profiles and prediction table.**
Q2	**DNS answers depend on resolver view, TTL, delegation and configuration.**	**Record workflow, six test cases and countermeasure plan.**
Q3	**Public business context can support plausible social-engineering pretexts.**	**Source-to-technique map and awareness controls.**
Q4	**Scope-first validation prevents invalid items from consuming additional effort.**	**Disposition rules and five adversarial sequences.**
Q5	**Tree/graph traversal provides systematic coverage with explicit stop conditions.**	**Hierarchy, pseudocode and test structures.**
Q6	**Hybrid collection is generally more balanced than relying on speed or quietness alone.**	**Scope-size comparison and redundancy analysis.**
Q7	**An evidence-led redesign can improve efficiency while preserving scope compliance.**	**Original-versus-redesigned validation comparison.**

9.2 Conclusion

This assignment designed and evaluated a set of authorized footprinting and reconnaissance workflows. The report demonstrates that reliable assessment depends on more than collecting a large number of records. Each finding must be tied to a source, timestamp, scope decision and confidence level. DNS information must be interpreted with awareness of resolver caching, delegation and split-horizon behavior. Public business information should be used to strengthen awareness and defensive controls rather than to target real individuals. Validation and hierarchical traversal require explicit boundary conditions so that incomplete, duplicated or outof-scope information does not contaminate the final report.

The integrated redesign places scope validation before expensive processing and introduces clear reason codes for pass, re-query and reject decisions. The overall engineering judgment is to use a hybrid, allowlist-driven, evidence-based workflow that can scale while remaining auditable and authorized.

9.3 Limitations and future improvements

- The worked examples and numerical tables are illustrative; live observations must be collected in an authorized lab.
- Search-engine indexing and archived content may change over time, so the report should preserve access dates and evidence snapshots where permitted.
- Automated parsing may misclassify aliases, shared hosting or third-party services; human review remains necessary.
- Future work can add structured evidence storage, automated report generation, dashboards for coverage and exception tracking, and versioned scope approvals.

10. REFERENCES

[1] Internet Engineering Task Force (IETF), RFC 1034, "Domain Names – Concepts and Facilities," 1987.

[2] IETF, RFC 1035, "Domain Names – Implementation and Specification," 1987.

[3] IETF, RFC 5936, "DNS Zone Transfer Protocol (AXFR)," 2010.

[4] IETF, RFC 8499, "DNS Terminology," 2019.

[5] IETF, RFC 9082, "Registration Data Access Protocol (RDAP) Query Format," 2021.

[6] IETF, RFC 9083, "JSON Responses for the Registration Data Access Protocol (RDAP)," 2021.

[7] National Institute of Standards and Technology (NIST), SP 800-115, "Technical Guide to Information Security Testing and Assessment," 2008.

[8] NIST, SP 800-53 Rev. 5, "Security and Privacy Controls for Information Systems and Organizations," 2020.

[9] OWASP Foundation, "Web Security Testing Guide," Information Gathering section.

[10] MITRE, "ATT&CK Enterprise – Phishing and Social Engineering-related techniques," for defensive awareness context.

[11] ISC, "BIND 9 Administrator Reference Manual," DNS configuration and zone-transfer documentation.

[12] ITA1439 Ethical Hacking, CO2 Assignment 2 – official assignment brief supplied for this report.

[13]

Note: Consult the latest official editions and course-approved references before final submission. Reference entries are provided as a starting bibliography; add access dates and URLs for online materials actually consulted.

APPENDIX A – COMMAND REFERENCE

Purpose	Command / operator	Use note
WHOIS	whois example.com	Passive registration lookup; verify source and date.
A record	dig example.com A	Use only approved domains.
MX record	dig example.com MX	Documents mail exchanger records.
NS record	dig example.com NS	Documents name-server delegation.
TXT record	dig example.com TXT	Review policy and verification strings carefully.
nslookup A	nslookup -type=A example.com	Alternative DNS query utility.
Search PDF	site:example.com filetype:pdf	Search public indexed documents.
Search title	site:example.com intitle:annual report	Search pages with relevant title terms.
AXFR (authorized only)	dig @AUTHORIZED_NS example.com AXFR	Only run against a specifically authorized lab server.

APPENDIX B – EVIDENCE COLLECTION TEMPLATES

B.1 DNS evidence log

Evidence ID	Hostname	Record type	Resolver	TTL	Raw result / file	Scope	Time
DNS-001		A					
DNS-002		MX					
DNS-003		NS					
DNS-004		TXT					

B.2 Public-source evidence log

Item ID	Source type	Public URL / query	Access date	Factual summary	Technique mapping	Control
CI-001						
CI-002						
CI-003						

B.3 Validation log

Item ID	Scope	Freshness	Duplicate	Reliability	Disposition	Reason code
VAL-001						
VAL-002						
VAL-003						

B.4 Student execution checklist

- Fill in student name, register number and submission date on the cover page.
- Replace all illustrative observations and numerical values with actual authorized lab results.
- Attach raw command outputs or screenshots with timestamps and tool versions.
- Confirm every target and server is within the approved written scope.
- Keep third-party services and personal data out of active testing unless explicitly authorized.
- Add page-specific figure and table references if your faculty requires them.
- Proofread the final report and verify that all seven questions are addressed.